KinBech

Advanced Security Hardening

Developer Handoff Checklist - Step by Step

Chhote script-kiddie se lekar serious attacker tak.
Har jagah UX note hai taaki security se app mushkil na bane.

96	11	4	14
Hardenings	Categories	Phases	Phase 1 steps

Phase 1 **Phase 2** **Phase 3** **Phase 4**

Kaise use karein

Yeh document developer ko step-by-step kaam dene ke liye hai. Pehle Phase roadmap dekho, phir har phase ke steps ek ek karke complete karo. Detailed checklist (96 items) end mein hai.

Phase order follow karo
Phase 1 > 2 > 3 > 4. OTP sabse last mein hai.

Har step ke box pe tick
Step complete hone par checkbox mark karo.

UX note padho
Security se user ka experience kharab na ho - UX line har step mein hai.

PR mein item # likho
Checklist ka # reference PR description mein do (e.g. #9, #41).

Phase Roadmap

Phase 1 - Ship Blocker
Launch se pehle compulsory. (OTP skip rahega)
14 steps
31 checklist items

Phase 2 - Hard Shell
Launch ke aas-paas: perimeter + admin + data protection.
9 steps
46 checklist items

Phase 3 - Fortress
Advanced hardening: growth ke saath.
7 steps
14 checklist items

Phase 4 - OTP (Last)
OTP bucket - sabse last mein.
4 steps
OTP bucket

Note: "Hack impossible" mathematically possible nahi - lekin itna harden kar sakte ho ki opportunistic hacker cost/effort se haar jaye aur genuine user ko farq na pade.

1. Phase 1 - Ship Blocker

Launch se pehle compulsory. (OTP skip rahega)

14 steps

1. **/auth/complete-signup band**
   Endpoint ko proof-token ke bina band karo. Signup UX same rahe, bypass possible na ho.
   UX: UX same rahe
   Ref: #9 ☐

2. **Admin default creds hatao**
   Default creds git se remove; first login pe password change force. Invite passwords crypto-strong ya invite link email.
   UX: First login pe change-password screen
   Ref: #41, #35 ☐

3. **KYC / sensitive data hide**
   Output DTO use karo. Full Mongo doc ya KYC fields response mein kabhi na jaye.
   UX: Invisible
   Ref: #18 ☐

4. **Rate limiting**
   Global + per-route + per-user limits. 429 pe friendly message.
   UX: "Try again in Xs"
   Ref: #11 ☐

5. **RBAC**
   super_admin / admin / moderator / support scopes. Sirf super_admin admins create/delete kare.
   UX: UI mein sirf allowed menus
   Ref: #33, #34 ☐

6. **Suspended / banned block**
   Har request pe user status check karo.
   UX: "Account restricted"
   Ref: #3 ☐

7. **CORS allowlist**
   Sirf exact origins allow karo.
   UX: Invisible
   Ref: #14 ☐

8. **Helmet + security headers**
   Helmet, HSTS, nosniff, frameguard enable.
   UX: Invisible
   Ref: #13 ☐

9. **Cleartext HTTP off**
   Release build mein sirf HTTPS. Cleartext traffic disable.
   UX: Prod HTTPS only
   Ref: #44 ☐

10. **Tokens SecureStore mein**
    Tokens Keychain/SecureStore mein; AsyncStorage nahi.
    UX: Invisible
    Ref: #43 ☐

11. **JWT hygiene**
    Short-lived access token, token version + revoke on logout/password change/suspend. Role sirf DB se.
    UX: Logout sab devices se option
    Ref: #1, #2, #10 ☐

12 

Body size limits

Auth 16kb, general 1mb, upload alag limit.

UX: Badi photo pe clear error

Ref: #15

☐

13 

Errors & logs saaf

Stack trace client ko nahi. Tokens/OTP/secrets kabhi log mat karo. Token logs __DEV__ ke peeche.

UX: Friendly error messages

Ref: #23, #24, #49

☐

14 

Audit basics

Kaun ne kya change kiya - basic audit trail admin actions ka.

UX: UI "Activity" later

Ref: #37

☐

2. Phase 2 - Hard Shell

Launch ke aas-paas: perimeter + admin + data protection.

9 steps

1. **Cloudflare + WAF**
   Proxy, WAF rules, bot fight, DDoS protection.
   UX: Challenge sirf spikes pe
   Ref: #21, #22, #67, #74
   - [ ]

2. **Private docs bucket**
   KYC/docs private bucket mein + short-TTL signed URLs.
   UX: Owner/admin instantly khol sake
   Ref: #29
   - [ ]

3. **Image re-encode**
   Magic-byte MIME check + server-side re-encode, EXIF GPS strip.
   UX: "Unsupported format" message
   Ref: #26, #27
   - [ ]

4. **AI quotas**
   Per-user quota + cost caps AI endpoints pe.
   UX: "AI limit reached today"
   Ref: #84
   - [ ]

5. **Admin 2FA**
   TOTP authenticator, sirf admin accounts pe.
   UX: Users pe nahi lagana
   Ref: #5
   - [ ]

6. **CSP strict**
   Admin SPA + client website pe CSP, X-Frame-Options, Referrer-Policy.
   UX: Invisible
   Ref: #38, #86
   - [ ]

7. **Device sessions**
   Sessions list + revoke from Profile.
   UX: Profile > Sessions > revoke
   Ref: #4
   - [ ]

8. **Full audit log**
   Detailed audit log + admin UI mein Activity page.
   UX: Compliance ready
   Ref: #37
   - [ ]

9. **Monitoring & alerts**
   5xx spike, auth surge, disk alerts.
   UX: Fix before users notice
   Ref: #80
   - [ ]

3. Phase 3 - Fortress

Advanced hardening: growth ke saath.

7 steps

1. **Refresh token rotation**
   Silent refresh + rotation + reuse detection.
   UX: User ko re-login nahi
   Ref: #1 ☐

2. **Certificate pinning**
   Pin rotation plan ke saath - warna app break.
   UX: Invisible
   Ref: #45 ☐

3. **Play Integrity / App Attest**
   Backend device trust; old phones pe soft fail.
   UX: Soft fail, block nahi
   Ref: #53 ☐

4. **Field-level encryption**
   PAN/VAT at rest encrypted; admin decrypt only when needed.
   UX: Admin only
   Ref: #61 ☐

5. **Captcha on risk**
   Turnstile sirf suspicious traffic pe.
   UX: 99% users ko nahi dikhe
   Ref: #85 ☐

6. **Penetration test**
   Big launch se pehle external/internal pen-test.
   UX: -
   Ref: #90 ☐

7. **Bug bounty (light)**
   Launch ke baad light bounty program.
   UX: -
   Ref: #91 ☐

4. Phase 4 - OTP (Last)

OTP bucket - sabse last mein.

4 steps

1 **Random OTP**
Crypto-random OTP; fixed/test OTP prod mein kabhi nahi.
UX: Invisible
Ref: OTP ☐

2 **Real SMS provider**
Real SMS gateway integrate karo.
UX: Fast delivery
Ref: OTP ☐

3 **Attempt limit / lock**
Wrong attempts pe temporary lock + backoff.
UX: Clear "try later" message
Ref: OTP ☐

4 **6-digit + expiry**
6-digit code with short expiry, resend cooldown.
UX: Countdown timer
Ref: OTP ☐

Full Checklist (96 items)

Sab categories A se K tak. Phase column batata hai kaun sa item kab karna hai.

A. Auth & Account

Login, tokens, sessions, passwords

10 items

#	Hardening	UX note	Phase	Done
1	JWT short-lived access + refresh token rotation	Silent refresh - user ko dobara login na karna pade	Phase 3	☐
2	Token version / revoke on logout, password change, suspend	Logout sab devices se option do	Phase 1	☐
3	Suspended / banned users har request pe block	Clear message: "Account restricted"	Phase 1	☐
4	Device session list (kaunse phones logged in)	Profile > Sessions > revoke	Phase 2	☐
5	Admin: 2FA (TOTP / authenticator)	Login pe ek extra step - users pe mat lagao pehle	Phase 2	☐
6	Admin: login IP allowlist / geo alert	Sirf team ke liye	Phase 2	☐
7	Failed login lockout + exponential backoff	Soft: 5 fail > 1 min wait, phir progressive	Phase 2	☐
8	Password: strong policy + breach check (HaveIBeenPwned k-anonymity)	Admin accounts pe; mobile OTP users pe nahi	Phase 2	☐
9	/auth/complete-signup band / proof-token	UX same rahe, bypass band	Phase 1	☐
10	Role sirf DB se; JWT role trust mat karo	Invisible to user	Phase 1	☐

B. API / Backend Armor

Rate limits, headers, validation, errors

15 items

#	Hardening	UX note	Phase	Done
11	Rate limit: global + per-route + per-user	Soft limits; 429 pe friendly "try again in Xs"	Phase 1	☐
12	Slow-down (delay) after abuse, not hard ban pehle	Better UX than instant block	Phase 2	☐
13	Helmet + HSTS + nosniff + frameguard	Invisible	Phase 1	☐
14	CORS allowlist exact origins	Invisible	Phase 1	☐
15	Request size limits (auth 16kb, general 1mb, upload alag)	Badi photo pe clear error	Phase 1	☐
16	express-mongo-sanitize + ObjectId validation	Invisible	Phase 1	☐
17	Input schema validation (Zod/Joi) har endpoint	Clear field errors	Phase 1	☐
18	Output DTO - kabhi full Mongo doc mat bhejo	Invisible; KYC strip	Phase 1	☐
19	Idempotency keys sensitive POSTs pe	Double-tap se duplicate post na bane	Phase 2	☐
20	API versioning /v1	Future-safe	Phase 2	☐
21	WAF (Cloudflare) - SQLi/XSS/bot patterns	Challenge rare; normal users smooth	Phase 2	☐
22	Fail2ban / Cloudflare bot fight	Aggressive crawlers only	Phase 2	☐
23	Disable verbose logs in prod; never log tokens/OTP/body secrets	Invisible	Phase 1	☐
24	Central error codes; no stack traces to client	Friendly messages	Phase 1	☐
25	Health check alag; metrics internal only	/health lightweight, no secrets	Phase 1	☐

C. Files, Media, KYC

Uploads, storage, scanning, moderation

7 items

#	Hardening	UX note	Phase	Done
26	Magic-byte MIME check (client MIME trust mat karo)	Wrong file pe "unsupported format"	Phase 2	☐
27	Image re-encode server-side (strip EXIF GPS)	Privacy win; quality preserve	Phase 2	☐
28	Virus/malware scan uploads (ClamAV / cloud)	Async OK - listing pending status	Phase 2	☐
29	Private bucket for KYC/docs + signed URLs (short TTL)	Owner/admin open instantly	Phase 2	☐
30	Public listings: CDN + cache; no directory listing	Fast browse	Phase 2	☐
31	Upload quota per user/day	Soft: "daily limit reached"	Phase 2	☐
32	NSFW fail-closed in prod	False positive > appeal/report flow	Phase 2	☐

D. Admin Panel Lockdown

RBAC, audit, sessions, CSP

10 items

#	Hardening	UX note	Phase	Done
33	Real RBAC: super_admin / admin / moderator / support scopes	UI mein sirf allowed menus	Phase 1	☐
34	Sirf super_admin create/delete admins	Settings safe	Phase 1	☐
35	Crypto-strong invite passwords / invite link email	Alert mein weak random mat	Phase 1	☐
36	Admin JWT shorter + re-auth for destructive actions	Delete user pe password/2FA confirm	Phase 2	☐
37	Audit log: kaunne kya change kiya	Compliance; UI "Activity"	Phase 1	☐
38	CSP strict on admin SPA	Invisible	Phase 2	☐
39	httpOnly Secure SameSite cookie (ideal) ya short token + CSP	XSS se token chori mushkil	Phase 2	☐
40	Admin subdomain + IP/VPN (optional hard mode)	Team VPN once	Phase 2	☐
41	Remove default creds from git; force change on first login	First login UX	Phase 1	☐
42	Idle session timeout (15-30 min admin)	Warning toast before logout	Phase 2	☐

E. Mobile App

Storage, build hardening, device trust

11 items

#	Hardening	UX note	Phase	Done
43	Tokens in SecureStore / Keychain	Invisible	Phase 1	☐
44	Release: no cleartext HTTP	Prod HTTPS only	Phase 1	☐
45	Certificate pinning (optional advanced)	Pin rotate carefully - warna app break	Phase 3	☐
46	Root/jailbreak detection soft-warn (calls/wallet)	Block mat karo pehle; warn + limit	Phase 3	☐
47	Obfuscate release builds (ProGuard/R8, Hermes)	Invisible	Phase 3	☐
48	No secrets in app binary (Gemini/Agora cert server only)	Invisible	Phase 1	☐
49	Gate all token logs behind __DEV__	Invisible	Phase 1	☐
50	Biometric unlock for app reopen (optional)	User opt-in	Phase 3	☐
51	Screen capture block on chat/OTP screens (optional Android)	Privacy; kuch users dislike - setting	Phase 3	☐
52	Deep link validation (host allowlist)	Invisible	Phase 1	☐
53	Play Integrity / App Attest (advanced)	Backend trust device; soft fail for old phones	Phase 3	☐

F. Chat, Calls, Trust & Safety

Messaging abuse, privacy, reports

7 items

#	Hardening	UX note	Phase	Done
54	Chat: participant check har message/call pe	Already mostly - keep	Phase 1	☐
55	Phone number privacy prefs enforce	Meetup confirm pe reveal option	Phase 2	☐
56	Link warning + scam keyword filter	Soft interstitial, not silent drop	Phase 2	☐
57	Rate limit messages / media in chat	Spam bots; normal chat fine	Phase 2	☐
58	Report > auto-restrict thresholds	Fair: warning > limit > ban	Phase 2	☐
59	Agora tokens short TTL, channel auth	Invisible	Phase 2	☐
60	Block/report sync across devices	Instant feel	Phase 2	☐

G. Data & Privacy

Encryption, retention, legal flows

5 items

#	Hardening	UX note	Phase	Done
61	Field-level encryption for PAN/VAT at rest	Admin decrypt only when needed	Phase 3	☐
62	PII minimization in logs	Invisible	Phase 2	☐
63	Soft-delete + retention policy	"Delete account" real deletion path	Phase 3	☐
64	Export-my-data / delete-my-data (legal)	Settings flow	Phase 3	☐
65	Backup encryption + restore drills	Ops only	Phase 3	☐

H. Infra / Network (Server)

TLS, proxy, DB access, monitoring

15 items

#	Hardening	UX note	Phase	Done
66	TLS 1.2+ only; HSTS	Invisible	Phase 1	☐
67	Reverse proxy (nginx/Caddy) + Cloudflare	Faster + safer	Phase 2	☐
68	Hide server version headers	Invisible	Phase 1	☐
69	Mongo not public; VPC / Atlas IP allowlist	Invisible	Phase 1	☐
70	Least-privilege DB user (no atlasAdmin for app)	Invisible	Phase 1	☐
71	Secrets in vault / host env - never git	Invisible	Phase 1	☐
72	Separate staging + production	Devs staging pe test	Phase 1	☐
73	Automated security updates (OS + npm audit CI)	Invisible	Phase 2	☐
74	DDoS protection (Cloudflare)	Challenge only spikes pe	Phase 2	☐
75	SSH keys only, no password; fail2ban	Ops	Phase 2	☐
76	Non-root app process; read-only FS where possible	Invisible	Phase 2	☐
77	Resource limits (CPU/mem) + PM2 cluster	Crash isolation	Phase 2	☐
78	DB connection limits + query timeouts	Slow query pe timeout, hang nahi	Phase 2	☐
79	Offsite encrypted backups + restore test monthly	Ops	Phase 2	☐
80	Monitoring + alerts (5xx spike, auth surge, disk)	Fix before users notice	Phase 2	☐

I. Fraud / Business Logic

Verification, spam, abuse, AI cost

5 items

#	Hardening	UX note	Phase	Done
81	Shop verification workflow before trust badges	Pending state clear UI	Phase 2	☐
82	Listing price / spam heuristics	Auto-hold rare; notify seller	Phase 2	☐
83	Referral / wallet abuse detection	Fair limits	Phase 2	☐
84	AI endpoint: quota per user + cost caps	"AI limit reached today"	Phase 2	☐
85	Captcha / Turnstile sirf suspicious traffic pe	99% users kabhi na dekhein	Phase 3	☐

J. Client Website

Browser-side hardening

4 items

#	Hardening	UX note	Phase	Done
86	CSP, X-Frame-Options, Referrer-Policy	Invisible	Phase 2	☐
87	No secrets in Vite bundle	Invisible	Phase 2	☐
88	Dependency audit + lockfile	CI	Phase 2	☐
89	Subresource integrity if CDN scripts	Invisible	Phase 2	☐

K. Process

Hack "impossible" ka asli hissa

7 items

#	Practice	Phase	Done
90	Penetration test before big launch	Phase 3	☐
91	Bug bounty (light) after launch	Phase 3	☐
92	Incident response plan (who rotates secrets)	Ongoing	☐
93	Regular access review (ex-employees admin hatana)	Ongoing	☐
94	Dependency CVE alerts (Dependabot/Snyk)	Ongoing	☐
95	Chaos: backup restore drill	Ongoing	☐
96	Security changelog for each release	Ongoing	☐

!. UX Golden Rules

Taaki user pareshan na ho

1. Friction admin pe zyada, buyer/seller pe kam
2. Progressive security - pehle soft (warn / delay), phir hard (block)
3. Clear messages - kabhi "Error 403 Forbidden" nahi; "Try again in 30s" / "Account under review"
4. Opt-in advanced - biometric, screenshot block, PIN
5. Captcha / 2FA / VPN sirf risk pe - har click pe nahi
6. Fast path for good users - rate limits unke normal use se upar set karo

+. Dev Sign-off Tracker

Phase complete hone par fill karo

Phase	Developer	Start date	End date	Reviewed by	Status
Phase 1					☐
Phase 2					☐
Phase 3					☐
Phase 4					☐

Aakhri baat: Phase 1 (OTP skip) pehle implement karo. OTP changes sabse last mein.